ZAP por Informe de Escaneo Checkmarx

Sitio: http://localhost:5173

Generado a vie, 23 oct 2026 17:34:53

ZAP Versión: 2.17.0

ZAP by Checkmarx

Sumario de Alertas

Nivel de riesgo	Número de Alertas
Alto	0
Medio	3
Bajo	1
Informativo	2

Insights

Level	Razón	Site	Descripción	Statistic
Bajo	Advertencia		ZAP warnings logged - see the zap. log file for details	1
Información	Informativo		Percentage of network failures	1 %
Información	Informativo	http://localhost:5173	Percentage of responses with status code 2xx	98 %
Información	Informativo	http://localhost:5173	Percentage of responses with status code 4xx	1 %
Información	Informativo	http://localhost:5173	Percentage of endpoints with content type application /json	14 %
Información	Informativo	http://localhost:5173	Percentage of endpoints with content	14 %

			type image /x-icon	
Información	Informativo	http://localhost:5173	Percentage of endpoints with content type text /html	42 %
Información	Informativo	http://localhost:5173	Percentage of endpoints with content type text /javascript	28 %
Información	Informativo	http://localhost:5173	Percentage of endpoints with method GET	100 %
Información	Informativo	http://localhost:5173	Count of total endpoints	7

Alertas

Nombre	Nivel de riesgo	Número de Instancias
Cabecera Content Security Policy (CSP) no configurada	Medio	3
Falta atributo de integridad de recursos secundarios	Medio	3
Falta de cabecera Anti-Clickjacking	Medio	3
Falta encabezado X-Content-Type-Options	Bajo	Systemic
Aplicación Web Moderna	Informativo	3
Divulgación de información - Comentarios sospechosos	Informativo	1

Detalles de la Alerta

Medio	Cabecera Content Security Policy (CSP) no configurada
Descripción	La Política de seguridad de contenido (CSP) es una capa adicional de seguridad que ayuda a detectar y mitigar ciertos tipos de ataques, incluidos Cross Site Scripting (XSS) y ataques de inyección de datos. Estos ataques se utilizan para todo, desde el robo de datos hasta la desfiguración del sitio o la distribución de malware. CSP proporciona un conjunto de encabezados HTTP estándar que permiten a los propietarios de sitios web declarar fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página; los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustados como applets de Java, ActiveX, archivos de audio y video.
URL	http://localhost:5173/
Nombre del Nodo	http://localhost:5173/
Método	GET
Ataque	

Evidencia	
Otra información	
URL	http://localhost:5173/robots.txt
Nombre del Nodo	http://localhost:5173/robots.txt
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/sitemap.xml
Nombre del Nodo	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	
Otra información	
Instancia	3
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. esté configurado para establecer la cabecera Content-Security-Policy.
Referencia	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medio	**Falta atributo de integridad de recursos secundarios**
Descripción	Falta el atributo de integridad en una etiqueta de script o enlace servida por un servidor externo. La etiqueta de integridad evita que un atacante que haya obtenido acceso a este servidor inyecte un contenido malicioso.
URL	http://localhost:5173/
Nombre del Nodo	http://localhost:5173/
Método	GET
Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Roboto:wght@300;400;500;700&display=swap" rel="stylesheet" />
Otra información	
URL	http://localhost:5173/robots.txt
Nombre del Nodo	http://localhost:5173/robots.txt

Método	GET
Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Roboto:wght@300;400;500;700&display=swap" rel="stylesheet" />
Otra información	
URL	http://localhost:5173/sitemap.xml
Nombre del Nodo	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Roboto:wght@300;400;500;700&display=swap" rel="stylesheet" />
Otra información	
Instancia	3
Solución	Proporcionar un atributo de integridad válido a la etiqueta.
Referencia	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Medio	**Falta de cabecera Anti-Clickjacking**
Descripción	La respuesta no protege contra ataques de "ClickJacking". Debes incluir Content-Security-Policy con la directiva "frame-ancestors" o X-Frame-Options.
URL	http://localhost:5173/
Nombre del Nodo	http://localhost:5173/
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/robots.txt
Nombre del Nodo	http://localhost:5173/robots.txt
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:5173/sitemap.xml
Nombre del Nodo	http://localhost:5173/sitemap.xml
Método	GET
Ataque	

Evidencia	
Otra información	
Instancia	3
Solución	Los navegadores web modernos admiten las cabeceras HTTP Content-Security-Policy y X-Frame-Options. Asegúrese de que una de ellas está configurada en todas las páginas web devueltas por su sitio/aplicación. Si espera que la página esté enmarcada solo por páginas en su servidor (por ejemplo, si forma parte de un FRAMESET), utilice SAMEORIGIN; de lo contrario, si no espera que la página esté enmarcada, utilice DENY. Alternativamente, considere implementar la directiva "frame-ancestors" de la Política de Seguridad de Contenidos.
Referencia	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Bajo	**Falta encabezado X-Content-Type-Options**
Descripción	La cabecera Anti-MIME-Sniffing X-Content-Type-Options no se ha establecido en 'nosniff'. Esto permite que las versiones anteriores de Internet Explorer y Chrome realicen MIME-sniffing en el cuerpo de la respuesta, lo que puede provocar que el cuerpo dé la respuesta se interprete y se muestre como un tipo de contenido distinto del tipo de contenido declarado. Las versiones actuales (principios de 2014) y heredadas de Firefox utilizarán el tipo de contenido declarado (si se establece uno), en lugar de realizar MIME-sniffing.
URL	http://localhost:5173/
Nombre del Nodo	http://localhost:5173/
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/favicon.ico
Nombre del Nodo	http://localhost:5173/favicon.ico
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/manifest.json
Nombre	

del Nodo	http://localhost:5173/manifest.json
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/robots.txt
Nombre del Nodo	http://localhost:5173/robots.txt
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:5173/sitemap.xml
Nombre del Nodo	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
Instancia	Systemic
Solución	Asegúrese de que la aplicación/servidor web establece el encabezado Content-Type adecuadamente, y que establece el encabezado X-Content-Type-Options a 'nosniff' para todas las páginas web. Si es posible, asegúrese de que el usuario final utiliza un navegador web moderno y compatible con los estándares que no realiza MIME-sniffing en absoluto, o que puede ser dirigido por la aplicación web/servidor web para que no realice MIME-sniffing.
Referencia	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informativo	**Aplicación Web Moderna**

Descripción	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://localhost:5173/
Nombre del Nodo	http://localhost:5173/
Método	GET
Ataque	
Evidencia	<script type="module">import { injectIntoGlobalHook } from "/@react-refresh"; injectIntoGlobalHook(window); window.$RefreshReg$ = () => {}; window.$RefreshSig$ = () => (type) => type;</script>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
URL	http://localhost:5173/robots.txt
Nombre del Nodo	http://localhost:5173/robots.txt
Método	GET
Ataque	
Evidencia	<script type="module">import { injectIntoGlobalHook } from "/@react-refresh"; injectIntoGlobalHook(window); window.$RefreshReg$ = () => {}; window.$RefreshSig$ = () => (type) => type;</script>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
URL	http://localhost:5173/sitemap.xml
Nombre del Nodo	http://localhost:5173/sitemap.xml
Método	GET
Ataque	
Evidencia	<script type="module">import { injectIntoGlobalHook } from "/@react-refresh"; injectIntoGlobalHook(window); window.$RefreshReg$ = () => {}; window.$RefreshSig$ = () => (type) => type;</script>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
Instancia	3
Solución	Se trata de una alerta informativa, por lo que no es necesario realizar ningún cambio.
Referencia	
CWE Id	
WASC Id	
Plugin Id	10109

Informativo	**Divulgación de información - Comentarios sospechosos**
Descripción	The response appears to contain suspicious comments which may help an attacker.
URL	http://localhost:5173/@vite/client
Nombre del Nodo	http://localhost:5173/@vite/client
Método	GET
Ataque	
Evidencia	`\0`, a convention from the rollup ecosyste
	The following pattern was used: \bFROM\b and was detected in likely comment: "/**

Otra información	* Plugins that use 'virtual modules' (e.g. for helper functions), prefix the * module ID with `\0`, a convention from the ro", see evidence field for the suspicious comment/snippet.
Instancia	1
Solución	Eliminar todos los comentarios que muestren información que pueda ayudar a un atacante y solucionar el problema al que se refieren.
Referencia	
CWE Id	615
WASC Id	13
Plugin Id	10027